Security Findings

TRACEGUARD | Evidence snapshot

Schema Version
1.0

Bundle Id
141d20fe-a641-404b-86cf-11124e6be45c

Generated At
2026-10-31T23:05:47.403Z

Advisory Snapshot Id
4c39ba350422d87221eeb59b11d3cafd88595791f9c97a8e3d32a2eb28448984

Inventory Counts

Project Modules
1

Unique Packages
1

Unique Package Versions
1

Dependency Instances
1

Direct Dependencies
1

Transitive Only Dependencies
0

Unknown Relationships
0

Dependency Edges
1

Unresolved Declarations
0

Scan Evidence

Scanner Version
0.2.0

Archive Sha256
8e590fb7559d410dad475198b93df9c1ac9c216073581ceb978c3b19b2322a60

Revision Status
unknown

Inventory Sha256
cc42bf40510dcd5a85d401114cb26b84e2dc5ac2ac2a011da4cb415d321680fd

Languages

1.
JavaScript

Projects

1.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

2.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

Metadata Hashes

1.

Path
package-lock.json

Sha256
2ba44094cdd18baf4af77414649dcee2b094a1ec27786be907759740db06a319

2.

Path
package.json

Sha256
1fb0138b887620f5958630e97b8dc82fbc8ab22719411050e291903d1fd32fc8

Scan

Id
79573486-0a6c-48e6-8f41-1295a790db58

Source
ZIP upload

Created At
2026-10-31T23:05:44.548Z

Inventory Sha256
cc42bf40510dcd5a85d401114cb26b84e2dc5ac2ac2a011da4cb415d321680fd

Coverage

Status
complete

Checked At
2026-10-31T23:05:44.550Z

Package Instances
1

Matched
1

No Known Match
0

Unknown
0

Findings Included
1

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per finding are included. Descriptions, references, paths and source evidence are bounded.

6.
Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning dependency declaration or parent. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

Report Type
security-findings

Title
Security Findings

Findings

1.

Id
F-001

Package

Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Install Path
node_modules/lodash

Project
package-lock.json

Is Project
false

Direct

true

Transitive
false

Resolved
https://registry.npmjs.org/lodash/-/lodash-4.17.20.tgz

Ecosystem
npm

Source File
package-lock.json

Project Path
.

Parent Ids

1.
urn:traceguard:component:f7dd3cc7a677a4603874ca2973e47a431ce3bd99 8c3e7e92237762327e666b24

Declared Constraints

1.
4.17.20

Resolution Confidence
recorded-lock

Purl
pkg:npm/lodash@4.17.20

Limitations
(none recorded)

What Is Wrong
OSV returned 5 advisory ID(s) for lodash@4.17.20 at this recorded dependency location.

Why It Matters
The recorded dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

Advisories

1.

Id
GHSA-29mw-wpgm-hmr9

Source
https://api.osv.dev/v1/vulns/GHSA-29mw-wpgm-hmr9

Verification
verified

Summary
Regular Expression Denial of Service (ReDoS) in lodash

Description
All versions of package lodash prior to 4.17.21 are vulnerable to Regular Expression Denial of Service (ReDoS) via the `toNumber`, `trim` and `trimEnd` functions.

Steps to reproduce (provided by reporter Liyuan Chen):
```js
var lo = require('lodash');

function build_blank(n) {
    var ret = "1"
    for (var i = 0; i < n; i++) {
        ret += " "
    }
    return ret + "1";
}
var s = build_blank(50000) var time0 = Date.now();
```

```
lo.trim(s)
var time_cost0 = Date.now() - time0;
console.log("time_cost0: " + time_cost0);
var time1 = Date.now();
lo.toNumber(s) var time_cost1 = Date.now() - time1;
console.log("time_cost1: " + time_cost1);
var time2 = Date.now();
lo.trimEnd(s);
var time_cost2 = Date.now() - time2;
console.log("time_cost2: " + time_cost2);
```

Aliases

1.
CVE-2020-28500

Severity

1.

Type
CVSS_V3

Score
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Fixed Versions

1.
4.17.21

References

1.
https://osv.dev/vulnerability/GHSA-29mw-wpgm-hmr9

2.
https://nvd.nist.gov/vuln/detail/CVE-2020-28500

3.
https://github.com/github/advisory-database/pull/6139

4.
https://github.com/lodash/lodash/pull/5065

5.
https://github.com/lodash/lodash/pull/5065/commits/02906b8191d3c1 00c193fe6f7b27d1c40f200bb7

6.
https://github.com/lodash/lodash/commit/c4847ebe7d14540bb28a8b932 a9ce1b9ecbfee1a

7.
https://www.oracle.com/security-alerts/cpuoct2021.html

8.
https://www.oracle.com/security-alerts/cpujul2022.html

9.
https://www.oracle.com/security-alerts/cpujan2022.html

10.
https://www.oracle.com//security-alerts/cpujul2021.html

11.
https://snyk.io/vuln/SNYK-JS-LODASH-1018905

12.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074893

13.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074895

14.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074892

15.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074894

Modified
2025-09-29T21:12:31.102523Z

Severity Label
MODERATE

Affected Versions

1.
SEMVER: [{"introduced":"4.0.0"},{"fixed":"4.17.21"}]

2.

Id
GHSA-35jh-r3h4-6jhm

Source
https://api.osv.dev/v1/vulns/GHSA-35jh-r3h4-6jhm

Verification
verified

Summary
Command Injection in lodash

Description
`lodash` versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Aliases

1.
CVE-2021-23337

Severity

1.

Type
CVSS_V3

Score
CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Fixed Versions

1.
4.17.21

References

1.
https://osv.dev/vulnerability/GHSA-35jh-r3h4-6jhm

2.
https://nvd.nist.gov/vuln/detail/CVE-2021-23337

3.
https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b 5a91dde28ba4b1c

4.
https://www.oracle.com/security-alerts/cpuoct2021.html

5.
https://www.oracle.com/security-alerts/cpujul2022.html

6.
https://www.oracle.com/security-alerts/cpujan2022.html

7.
https://www.oracle.com//security-alerts/cpujul2021.html

8.
https://snyk.io/vuln/SNYK-JS-LODASH-1040724

9.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929

10.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931

11.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928

12.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930

13.
https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932

14.
https://security.netapp.com/advisory/ntap-20210312-0006

15.
https://github.com/rubysec/ruby-advisory-db/blob/master/gems/loda sh-rails/CVE-2021-23337.yml

Modified
2026-10-17T02:55:38.085813876Z

Severity Label
HIGH

Affected Versions

1.
SEMVER: [{"introduced":"0"},{"fixed":"4.17.21"}]

3.

Id
GHSA-f23m-r3pf-42rh

Source
https://api.osv.dev/v1/vulns/GHSA-f23m-r3pf-42rh

Verification
verified

Summary
lodash vulnerable to Prototype Pollution via array path bypass in `_.unset` and `_.omit`

Description
Impact

Lodash versions 4.17.23 and earlier are vulnerable to prototype pollution in the `_.unset` and `_.omit` functions. The fix for [CVE-2025-13465](https://github.com/lodash/lodash/security/adviso ries/GHSA-xxjr-mmjv-4gpg) only guards against string key members, so an attacker can bypass the check by passing array-wrapped path segments. This allows deletion of properties from built-in prototypes such as `Object.prototype`, `Number.prototype`, and `String.prototype`.

The issue permits deletion of prototype properties but does not allow overwriting their original behavior.

Patches

This issue is patched in 4.18.0.

Workarounds

None. Upgrade to the patched version.

Aliases

1.
CVE-2026-2950

Severity

1.

Type
CVSS_V3

Score
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Fixed Versions

1.
4.18.0

References

1.
https://osv.dev/vulnerability/GHSA-f23m-r3pf-42rh

2.
https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh

3.
https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg

4.
https://nvd.nist.gov/vuln/detail/CVE-2026-2950

5.
https://github.com/lodash/lodash

Modified
2026-10-17T02:56:13.084362346Z

Severity Label
MODERATE

Affected Versions

1.
SEMVER: [{"introduced":"0"},{"fixed":"4.18.0"}]

4.

Id
GHSA-r5fr-rjxr-66jc

Source
https://api.osv.dev/v1/vulns/GHSA-r5fr-rjxr-66jc

Verification
verified

Summary
lodash vulnerable to Code Injection via `_.template` imports key names

Description
Impact

The fix for [CVE-2021-23337](https://github.com/advisories/GHSA-35jh-r3h4-6jhm) added validation for the `variable` option in `_.template` but did not apply the same validation to `options.imports` key names. Both paths flow into the same `Function()` constructor sink.

When an application passes untrusted input as `options.imports` key names, an attacker can inject default-parameter expressions that execute arbitrary code at template compilation time.

Additionally, `_.template` uses `assignInWith` to merge imports, which enumerates inherited properties via `for..in`. If `Object.prototype` has been polluted by any other vector, the polluted keys are copied into the imports object and passed to `Function()`.

Patches

Users should upgrade to version 4.18.0.

The fix applies two changes:
1. Validate `importsKeys` against the existing `reForbiddenIdentifierChars` regex (same check already used for the `variable` option)
2. Replace `assignInWith` with `assignWith` when merging imports, so only own properties are enumerated

Workarounds

Do not pass untrusted input as key names in `options.imports`. Only use developer-controlled, static key names.

Aliases

1.
CVE-2026-4800

Severity

1.

Type
CVSS_V3

Score
CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Fixed Versions

1.
4.18.0

References

1.
https://osv.dev/vulnerability/GHSA-r5fr-rjxr-66jc

2.
https://github.com/lodash/lodash/security/advisories/GHSA-r5fr-rjxr-66jc

3.
https://nvd.nist.gov/vuln/detail/CVE-2026-4800

4.
https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b 5a91dde28ba4b1c

5.
https://cna.openjsf.org/security-advisories.html

6.
https://github.com/advisories/GHSA-35jh-r3h4-6jhm

7.
https://github.com/lodash/lodash

Modified
2026-10-17T02:56:15.633068434Z

Severity Label
HIGH

Affected Versions

1.
SEMVER: [{"introduced":"4.0.0"},{"fixed":"4.18.0"}]

5.

Id
GHSA-xxjr-mmjv-4gpg

Source
https://api.osv.dev/v1/vulns/GHSA-xxjr-mmjv-4gpg

Verification
verified

Summary
Lodash has Prototype Pollution Vulnerability in `_.unset` and `_.omit` functions

Description
Impact

Lodash versions 4.0.0 through 4.17.22 are vulnerable to prototype pollution in the `_.unset` and `_.omit` functions. An attacker can pass crafted paths which cause Lodash to delete methods from global prototypes.

The issue permits deletion of properties but does not allow overwriting their original behavior.

Patches

This issue is patched on 4.17.23.

Aliases

1.
CVE-2025-13465

Severity

1.

Type
CVSS_V3

Score
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

2.

Type
CVSS_V4

Score
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:L/SC:H/SI:H/SA:H/E:P

Fixed Versions

1.
4.17.23

References

1.
https://osv.dev/vulnerability/GHSA-xxjr-mmjv-4gpg

2.
https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg

3.
https://nvd.nist.gov/vuln/detail/CVE-2025-13465

4.
https://github.com/lodash/lodash/commit/edadd452146f7e4bad4ea684e 955708931d84d81

5.
https://cert-portal.siemens.com/productcert/html/ssa-253495.html

6.
https://github.com/lodash/lodash

Modified
2026-10-17T02:55:54.229635593Z

Severity Label
MODERATE

Affected Versions

1.
SEMVER: [{"introduced":"4.0.0"},{"fixed":"4.17.23"}]

Dependency Impact

Parent Count
1

Parents

1.

Id
urn:traceguard:component:f7dd3cc7a677a4603874ca2973e47a431ce3bd99 8c3e7e92237762327e666b24

Name
traceguard-judge-fixture

Version
1.0.0

Install Path

Root Paths

1.

1.
urn:traceguard:component:f7dd3cc7a677a4603874ca2973e47a431ce3bd99 8c3e7e92237762327e666b24

2.
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Truncated

false

Reachability

Status
REACHABLE

Report

Status
REACHABLE

Reason
A syntactic call path reaches the user-declared affected export of the selected locked package instance.

Target

Package Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Export Name
default

Mapping
user-declared export; not independently verified

Coverage

Entrypoints

1.

File
src/entry.js

Symbol
handler

Analyzed Files

1.
src/entry.js

Source Files Available
1

Skipped Sources
(none recorded)

Functions Visited
1

Calls Examined
1

Complete For Declared Entrypoints
true

Boundary
Captured application source ? declared export of the selected locked npm package instance.

Evidence

1.

File
src/entry.js

Line
2

Column
1

Snippet
export function handler() {

Kind
entry

From
<declared entrypoint>

To
src/entry.js#handler

2.

File
src/entry.js

Line
3

Column
10

Snippet
return lodash({});

Kind
target

From
src/entry.js#handler

To
lodash@4.17.20:default

Gaps
(none recorded)

Limitations

1.
Syntactic, context-insensitive ESM traversal of captured JS/JSX/TS/TSX/MJS/CJS source; no code is executed.

2.
Entrypoints are user-declared. Module initialization and an optional named/default exported function are roots. Other externally invoked exports are outside coverage.

3.
Target mapping is user-declared and not verified against an advisory. A target denotes an exported API boundary, not an internal library function.

4.
External package initialization and internal code, node_modules, generated/missing source, native code, framework dispatch, callbacks, dynamic imports, CommonJS, reflection, and computed calls are not modeled.

5.
Branches are conservatively traversed without feasibility analysis. REACHABLE means a syntactic call path, not proven runtime execution or exploitability.

6.
NOT REACHABLE applies only to declared entrypoints, captured source, and the exported-boundary model. It is not evidence of application safety.

7.
Source capture: 200 files, 256 KiB/file, 2 MiB total. Traversal: 1,000 units, 5,000 calls, 100,000 AST visits; evidence limited to 100 records.

Exploitability
NOT ASSESSED

Inventory Warnings
(none recorded)

Package Risk

Checked At
2026-10-31T23:05:49.305Z

Coverage

Total
1

Metadata Checked
1

Unavailable

0

Skipped
0

Results

1.

Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Registry
sha512-PlhdFcillOINfeV7Ni6oF1TAEayyZBoZ8bcshTHqOYJYlrqzRK5hagpagk y5o4HfCzzd1TRkXPMFq6cKk9rGmA==

Shasum
b44a9b6297bcb698f1c51a3545a2b3b368d59c52

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIQDPF8qtGU3yxHj4Yw4h9hpt+DCVT9dlk9ApvKxVXPwv7AIgSLC2TkL6ONbFl hyV2ZcE4v52ANJMoA/HwKY+zKt9Kh4=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/lodash/4.17.20

Metadata

Description
Lodash modular utilities.

License
MIT

Repository

https://github.com/lodash/lodash.git

Homepage
https://lodash.com/

Maintainers

1.
bnjmnt4n

2.
jdalton

3.
mathias

Lifecycle Scripts

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/